3. Phishing and Social Engineering

3.1 Phishing and its Different Forms

3.1.1 Phishing

Phishing is a type of social engineering attack in which criminals impersonate a trusted organisation or individual in order to persuade victims to disclose sensitive information, transfer money, or visit a malicious website (National Institute of Standards and Technology, n.d.).

3.1.2 Spear Phishing

Unlike general phishing attacks, spear phishing is highly targeted. Attackers use information about a specific organisation or employee to make the message more convincing and realistic (National Cyber Security Centre, 2018).

Illustrative example of general phishing:

> *Your Disney+ account has been suspended. Click here.*

Illustrative example of spear phishing:

> *Hi Alex, I need you to check the new finance report.*

3.1.3 Smishing

Smishing is phishing conducted through SMS or other text messages. Attackers commonly use messages containing malicious links or other deceptive instructions to persuade victims to provide personal or financial information (Federal Bureau of Investigation, n.d.b).

Illustrative example:

> *Your parcel could not be delivered. Pay £3.50 to reschedule delivery.*

3.1.4 Vishing

Vishing is phishing carried out through phone calls, voice messages or Voice over Internet Protocol (VoIP). Attackers may impersonate an official organisation, such as a bank or government department, to gain trust and request personal information (Federal Bureau of Investigation, n.d.b; NCSC, 2021a).

Illustrative example:

I am calling from the Metropolitan Police. Someone has committed an offence using your National Insurance number. Please provide your National Insurance number so that we can verify your identity.

3.1.5 Business Email Compromise (BEC)

Business Email Compromise usually targets organisations. Attackers may spoof or compromise email accounts and impersonate a colleague, manager, executive or trusted business contact. BEC often aims to persuade the victim to make a financial transfer or change payment details (Federal Bureau of Investigation, n.d.a).

Illustrative example:

Please transfer £10,000 to the new bank account of this supplier.

3.2 Psychological Techniques

Phishing is not solely a technical problem; social-engineering attacks often rely on psychological techniques that influence how people respond to requests (Stylianou et al., 2025).

3.2.1 Authority

Authority is an important social-engineering technique because people may be more willing to follow instructions that appear to come from a manager, government organisation or other trusted authority figure (Stylianou et al., 2025). Williams et al. (2018) examined nine simulated spear-phishing emails sent to 62,000 employees and found that authority cues increased the likelihood that a user would click a suspicious link.

3.2.2 Urgency

Attackers often create artificial urgency by claiming that immediate action is required. This can reduce the time a victim has to evaluate a message carefully and can encourage faster decisions. Urgency is a recognised social-engineering technique in phishing messages (NCSC, 2021a; Williams et al., 2018).

Illustrative example:

Your account will be suspended in 50 minutes.

3.2.3 Fear

Fear can influence emotional decision-making. Scam messages may make a person panic or feel threatened in order to pressure them into acting without thinking carefully (NCSC, 2021a).

Illustrative example:

Suspicious activity has been detected. Your bank account will be locked.

3.2.4 Scarcity / Fear of Missing Out

Scarcity is used when a message suggests that an opportunity is limited or may disappear quickly. The NCSC notes that fear of missing out can make people respond more quickly to a scam message (NCSC, 2021a).

Illustrative example:

Only 4 places remaining. Claim your reward now or lose the opportunity.

Overall, the effectiveness of phishing often depends on manipulating normal human responses such as trust, authority, urgency, fear and scarcity (Stylianou et al., 2025; NCSC, 2021a).

3.3 Indicators of Phishing

According to the National Cyber Security Centre (NCSC, 2026), common indicators of phishing include:

- Misspelled or suspicious email addresses
- Unexpected attachments
- Generic greetings such as “Dear valued customer”
- Links that direct users to unknown websites
- Spelling and grammar mistakes
- Poor-quality or strange-looking logos
- Messages that pressure the user to act quickly

The sender's email address should be checked carefully because attackers may create addresses that differ from legitimate ones by only a single letter, number or symbol (Federal Bureau of Investigation, n.d.b).

Example:

Legitimate: support@paypal.com
Fake: support@paypa1.com

However, users should not rely only on these signs. The NCSC explains that modern scams are becoming more convincing and can sometimes fool experienced users, so a professional-looking message should not automatically be trusted (NCSC, 2021a).

3.4 What Should Someone Do if They Suspect or Click Phishing?

3.4.1 If a Message Looks Suspicious

If a message appears suspicious, the recipient should not click links, open attachments or use contact details provided in the message. Instead, the organisation should be contacted independently using verified details from its official website. The user can also visit the organisation's official website manually to check their account (NCSC, 2021a).

3.4.2 If the User Has Already Clicked or Shared Information

- If a password was entered, the user should change that password and any other accounts that use the same password (NCSC, 2021b).
- If banking details were shared, the user should contact their bank immediately (NCSC, 2021b).
- If a suspicious application or file was installed, the user should run a full antivirus scan and allow the security software to remove any problems it finds (NCSC, 2021b).
- If the incident happened on a work laptop or phone, the user should inform the organisation's IT department (NCSC, 2021b).

3.4.3 Organisational Response

At organisational level, phishing should be addressed through multiple layers of security rather than relying entirely on employees to recognise every attack. The NCSC recommends a layered approach that combines technical, process and people-based controls (NCSC, 2018).

- Email filtering and malware detection
- Multi-factor authentication (MFA)
- Anti-spoofing controls such as SPF, DKIM and DMARC
- Security-awareness training and simple reporting processes
- Security monitoring and logging
- A documented and practised incident-response plan

Employee awareness is important, but it should not be the organisation's only defence. The NCSC states that training cannot teach users to identify every phishing attempt, so technical controls and incident-response procedures are also required (NCSC, 2018).

Reference List

Federal Bureau of Investigation. (n.d.a) Business Email Compromise. [Online] Available from: https://www.fbi.gov/how-we-can-help-you/common-frauds-and-scams/business-email-compromise. [Accessed 30 September 2026].

Federal Bureau of Investigation. (n.d.b) Spoofing and Phishing. [Online] Available from: https://www.fbi.gov/how-we-can-help-you/common-frauds-and-scams/spoofing-and-phishing. [Accessed 30 September 2026].

National Cyber Security Centre. (2018) Phishing attacks: defending your organisation. [Online] Available from: https://www.ncsc.gov.uk/guidance/phishing. [Accessed 30 September 2026].

National Cyber Security Centre. (2021a) Phishing scams: how to spot and report them. [Online] Available from: https://www.ncsc.gov.uk/collection/phishing-scams/spot-scams. [Accessed 30 September 2026].

National Cyber Security Centre. (2021b) Phishing scams: If you've shared sensitive information. [Online] Available from: https://www.ncsc.gov.uk/collection/phishing-scams/what-to-do. [Accessed 30 September 2026].

National Cyber Security Centre. (2026) Small organisations guide to cyber security: spotting cyber attacks. [Online] Available from: https://www.ncsc.gov.uk/collection/small-organisations-guide-to-cyber-security/spotting-cyber-attacks. [Accessed 30 September 2026].

National Institute of Standards and Technology. (n.d.) Phishing. [Online] Available from: https://csrc.nist.gov/glossary/term/phishing. [Accessed 30 September 2026].

Stylianou, I., Bountakas, P., Zarras, A. and Xenakis, C. (2025) Suspicious minds: Psychological techniques correlated with online phishing attacks. *Computers in Human Behavior Reports*, [Online] 19, article 100694. Available from: https://doi.org/10.1016/j.chbr.2025.100694. [Accessed 30 September 2026].

Williams, E.J., Hinds, J. and Joinson, A.N. (2018) Exploring susceptibility to phishing in the workplace. *International Journal of Human-Computer Studies*, [Online] 120, pp. 1-13. Available from: https://doi.org/10.1016/j.ijhcs.2018.06.004. [Accessed 30 September 2026].